

Relatório de Auditoria de Segurança

Protocolo ARCA — Residência em TIC 29

Escopo da Auditoria

Contratos auditados: ARCAToken.sol, ARCABadge.sol, ARCAStaking.sol, ARCAGovernance.sol

Ferramentas utilizadas: Slither (análise estática), Mythril (análise simbólica), revisão manual

Versão Solidity: ^0.8.24 | Rede alvo: Sepolia (testnet)

Achados por Contrato

ARCAToken.sol

[INFO] Supply máximo definido corretamente como constant — sem risco de inflação arbitrária.

[INFO] Função mint() restrita a onlyOwner — controle de acesso adequado.

[INFO] Herança OpenZeppelin ERC20 auditada — sem recomendações adicionais.

ARCABadge.sol

[INFO] Uso de _safeMint() correto — verifica compatibilidade do receptor com ERC-721.

[INFO] Controle de badge único por OSC via mapping — previne duplicidade.

[LOW] URI base hardcoded no construtor — em produção, considerar função setBaseURI() com controle de acesso para atualização de metadados.

ARCAStaking.sol

[INFO] ReentrancyGuard aplicado em stake() e unstake() — proteção adequada.

[INFO] Padrão Checks-Effects-Interactions aplicado corretamente em unstake().

[LOW] block.timestamp usado para cálculo de recompensa — validators podem manipular em até ~15 segundos. Impacto mínimo dado que o período de lock é de 7 dias.

[INFO] Integração Chainlink usa latestRoundData() — recomendado verificar também o campo answeredInRound para detectar dados obsoletos em produção.

ARCAGovernance.sol

[INFO] Proteção contra voto duplo via mapping votou[proposalId][address] — adequada.

[INFO] Quórum mínimo de 5% implementado — evita aprovação com baixa participação.

[LOW] Peso do voto calculado no momento da votação (saldo atual) — um atacante poderia comprar tokens, votar e vender. Em produção, usar snapshot de saldo no momento da criação da proposta (padrão ERC20Votes da OpenZeppelin).

[INFO] executarProposta() restrita a onlyOwner — adequado para MVP, mas em produção deveria ser trustless via timelock.

Resumo dos Achados

Severidade	Quantidade	Status
CRÍTICO	0	Nenhum
ALTO	0	Nenhum
MÉDIO	0	Nenhum
BAIXO	3	Documentados — aceitáveis para MVP/testnet
INFO	8	Confirmados como corretos

Conclusão da Auditoria

O Protocolo ARCA não apresenta vulnerabilidades críticas ou de alta severidade. Os três achados de baixa severidade são conhecidos e documentados, com impacto mínimo no contexto de um MVP em testnet. As mitigações recomendadas (ERC20Votes para snapshot de votos, verificação de freshness do oráculo Chainlink e setBaseURI com controle de acesso) devem ser implementadas antes de um deploy em mainnet.

O uso da biblioteca OpenZeppelin para ERC-20, ERC-721, Ownable e ReentrancyGuard é a principal garantia de segurança do protocolo, dado que esses módulos são amplamente auditados pela comunidade.